

DAsynchronous Activity — AES Part 5

Team 1:

Gonzalez Fernandez Jonathan Uriel – 420051871 / jonathanuri123@gmail.com

Gabriel Hernández Yukioayax Canek – 321058526 / yukio.gabriel.h@gmail.com

Paz Rosas Jesús Eduardo – 315134854 / jesuspazrosas@gmail.com

Vázquez Apolonio Armando – 315140725 / armandovaz090@gmail.com

October 1, 2026

Team Proposals for File Protection

Gonzalez Fernandez Jonathan Uriel — AES-256 in GCM (Galois/Counter Mode)

Proposes an Authenticated Encryption with Associated Data (AEAD) construction combining Counter mode (CTR) for stream confidentiality with a GHASH universal hash over $GF(2^{128})$ to produce a 128-bit authentication tag. It guarantees deterministic detection of any in-transit payload tampering prior to plaintext release, requiring strict lifecycle governance to ensure the 96-bit nonce never repeats under the same key.

Gabriel Hernández Yukioayax Canek — AES-256 in CBC Mode with Encrypt-then-MAC (HMAC-SHA256)

Proposes block-based AES-CBC encryption with PKCS#7 padding using an unpredictable 128-bit Initialization Vector (IV) per file, paired with an Encrypt-then-MAC scheme using HMAC-SHA256 evaluated over the IV and ciphertext. Verifying the HMAC in constant time before checking the padding eliminates integrity manipulation and padding oracle vulnerabilities.

Paz Rosas Jesús Eduardo — ChaCha20-Poly1305 AEAD

Proposes a modern stream-based AEAD primitive pairing the 256-bit ChaCha20 cipher with the Poly1305 authenticator using a 96-bit nonce. This design provides high throughput and ensures constant-time execution by design, eliminating cache-timing side-channel risks on hardware platforms that lack dedicated CPU cryptographic acceleration.

Vázquez Apolonio Armando — AES-256 in CTR Mode with Asymmetric Digital Signatures (Ed25519)

Proposes a stream-oriented scheme using AES-CTR to process files without block padding overhead, delegating message integrity and non-repudiation to an asymmetric Ed25519 digital signature computed across the ciphertext and associated metadata. This design formally separates bulk symmetric confidentiality from origin authentication guarantees.

Additional Design Decisions and Security Requirements

1. Nonce/IV Governance and Uniqueness Policy

In stream and counter-based schemes (such as GCM, CTR, or ChaCha20), repeating a nonce under the same key breaches confidentiality by exposing underlying plaintext via keystream cancellation and compromising internal authentication keys. The architecture must enforce strict nonce uniqueness guarantees, using high-entropy random generation via an OS-level CSPRNG or monotonic deterministic counters coupled with mandatory key rotation thresholds before invocation limits are reached.

2. Cryptographic Metadata Authentication (AAD)

Encrypting raw file content is inadequate if an adversary can tamper with filenames (enabling path traversal or arbitrary overwrites), MIME types, identifiers, or operational timestamps. The design must mandate that container headers and contextual metadata be cryptographically bound as Additional Authenticated Data (AAD) within the cryptographic primitive, ensuring any header modification invalidates the container during verification.

3. Constant-Time Ingestion and Fail-Closed Verification

To eliminate padding oracle vulnerabilities and cache-timing side channels, the receiving pipeline must verify authentication tags or signatures in constant time prior to inspecting block padding or releasing plaintext buffers. Any mathematical verification failure must trigger an immediate fail-closed termination, producing no partial outputs, filesystem writes, or verbose error codes that leak cryptographic state.

4. Key Hierarchy, Robust KDF Derivation, and Memory Zeroization

Payloads must never be directly encrypted using static master keys or raw user passwords. The platform requires a formal key hierarchy utilizing a memory-hard Key Derivation Function (KDF such as Argon2id or PBKDF2) to protect local storage, along with single-use ephemeral session keys generated per file transaction and the strict overwriting (zeroization) of sensitive memory buffers immediately after execution.

Team Proposal Conclusion

As a team, we conclude that the optimal design for the Secure File Exchange Platform is a hybrid authenticated architecture centered on AES-256 in Galois/Counter Mode (GCM) as the primary payload cipher, with ChaCha20-Poly1305 designated as an architectural fallback for environments lacking hardware acceleration. While composition schemes like AES-CBC with Encrypt-then-MAC provide solid historical guarantees, they introduce unnecessary implementation complexity, padding-oracle risks, and processing overhead. Similarly, relying on unauthenticated stream modes with external signatures separates symmetric data protection from integrity validation, creating avoidable parser exposure. AES-256-GCM provides an integrated, standardized, and high-performance AEAD primitive that simultaneously guarantees semantic confidentiality and bit-level integrity detection via GHASH authentication tags. To ensure this construction is truly robust, our system design

mandates single-use ephemeral session keys, cryptographically binds all file metadata as Additional Authenticated Data (AAD), and enforces a strict fail-closed policy where unverified buffers are immediately discarded before disk release. This unified approach minimizes attack surface, mitigates memory-timing channels via dedicated CPU extensions, and guarantees end-to-end security across untrusted storage and transport environments.

References

Aumasson, J.-P. (2018). *Serious Cryptography: A Practical Introduction to Modern Encryption*. No Starch Press.

Ferguson, N., Schneier, B., & Kohno, T. (2010). *Cryptography Engineering: Design Principles and Practical Applications*. Wiley.

Katz, J., & Lindell, Y. (2015). *Introduction to Modern Cryptography* (2nd ed.). CRC Press.

Paar, C., & Pelzl, J. (2010). *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer.

Sakiyama, K., Sasaki, Y., & Li, Y. (2015). *Security of Block Ciphers: From Algorithm Design to Hardware Implementation*. Wiley-IEEE Press.

Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice* (7th ed.). Pearson.